Assignment 6 — Weeks 9–10: Atomic Red Team and APT29 TTP Analysis

Danial Rahman, CS-2421 — Detecting Spearphishing Attacks in Corporate Networks

11 November 2026

Week 9 — Atomic Red Team: Running the Emulation Plan and Scoring It in a SIEM

Project and weekly task

Project topic: Detecting Spearphishing Attacks in Corporate Networks. Student: Danial Rahman. Group: CS-2421. Course: Introduction to Threat Hunting (ITH). Assignment 6, part 1. Date: 11 November 2026.

Section 3.3 of the 2026–2027 syllabus sets the Week 9 practice task as: *run selected atomic tests (e.g., T1059, T1003); record and analyze the test results in a SIEM,* with the Atomic Red Team wiki and GitHub repository as recommended reading. This increment runs the nine Atomic tests from the Week 8 plan, including the two the syllabus names (T1059.001 and T1003.001). It then loads the resulting telemetry into a SIEM store and scores every Week 7 and Week 9 detection rule against every test.

Atomic Red Team in brief

Atomic Red Team (Red Canary) is a library of small, single-purpose tests, each mapped to one ATT&CK technique. Each test is a YAML entry with a stable `auto_generated_guid`, an executor (`command_prompt`, `powershell`, `manual`), input arguments, prerequisites and a cleanup command. They are run with the **Invoke-AtomicRedTeam** PowerShell module (`Invoke-AtomicTest T1059.001 -TestGuids <guid>`). The approach is *test → look for the telemetry → fix the detection*, and the unit of measurement is "did the SIEM see this technique?", not "did the attack succeed?".

Tests selected (pinned)

`scripts/fetch_atomics.py` reads the Week 8 plan, downloads each technique's YAML from `redcanaryco/atomic-red-team` at commit **a0e3f9bc69**, checks that each GUID matches the plan, and writes `atomics/selected_tests.json`. The exact commands therefore come from the real tests and are not retyped by hand.

Step	Technique	Atomic test	Executor	What it really runs
1	T1566.001	#1 Download Macro-Enabled	powershell	`Invoke-WebRequest` of

Step	Technique	Atomic test	Executor	What it really runs
		Phishing Attachment		`PhishingAttachment.xlsm` to `%TEMP%`
2	T1204.002	T1566.001 #2 Word spawned a command shell and used an IP address	powershell	Invoke-MalDoc: Word macro writes `art.jse` and runs `Shell "ping 8.8.8.8"`
3	T1059.001	#17 PowerShell Command Execution	command_prompt	`powershell.exe -e <base64>`
4	T1105	#7 certutil download (urlcache)	command_prompt	`cmd /c certutil -urlcache -split -f <url>`
5	T1547.001	#1 Reg Key Run	command_prompt	`REG ADD HKCU\...\Run /V "Atomic Red Team"`
6	T1053.005	#2 Scheduled task Local	command_prompt	`SCHTASKS /Create /SC ONCE /TN spawn`
7	T1003.001	#2 Dump LSASS.exe Memory using comsvcs.dll	powershell (admin)	`rundll32 comsvcs.dll, MiniDump <lsass pid> lsass-comsvcs.dmp full`
8	T1560.001	#4 Compress Data and lock with password (7zip)	command_prompt	`7z.exe u archive.7z *txt -pblue`
9	T1041	#1 C2 Data Exfiltration	powershell	`Invoke-WebRequest -Method POST` to the lab C2 `198.51.100.25:8080`

Execution: runbook and what is in this repository

`runbook/Invoke-Week9Atomics.ps1` is the lab runbook. It refuses to run on any host other than `LAB-WIN10-01`. For each step it fetches prerequisites, runs the test by GUID, writes UTC start and end times to `run_log.csv`, waits for the forwarder, runs the cleanup command, and pauses 5 minutes before the next step.

About the data. This repository runs in a Linux container and cannot run Windows tests. As in Weeks 5–7, the telemetry in `data/atomic_run_telemetry.ndjson` is **synthetic**, but it is built mechanically from the real tests by `scripts/generate_telemetry.py`:

- Each technique event uses the test's **actual command line**, with its default input arguments filled in.
- Each command is wrapped the way Invoke-AtomicRedTeam launches it: `cmd.exe /c …` for `command_prompt` and `powershell.exe & {…}` for `powershell`.
- A benign **baseline** is added: Update-Help, the Teams updater writing its Run key, an admin creating a backup task, 7-Zip without a password, a user saving a macro workbook from Excel, and the approved FIN-WS03 report automation from Week 7.

Every event carries a ground-truth label, `_truth`, with one of four values: `technique`, `proxy` (how the test stands in for the technique), `harness` (Invoke-AtomicRedTeam itself) or `baseline`. The label is used only for scoring; the queries never read it. After a real lab run, replace the NDJSON with a Splunk export and `run_log.csv` with the runbook's log, then re-run the scripts.

Recording the results in a SIEM

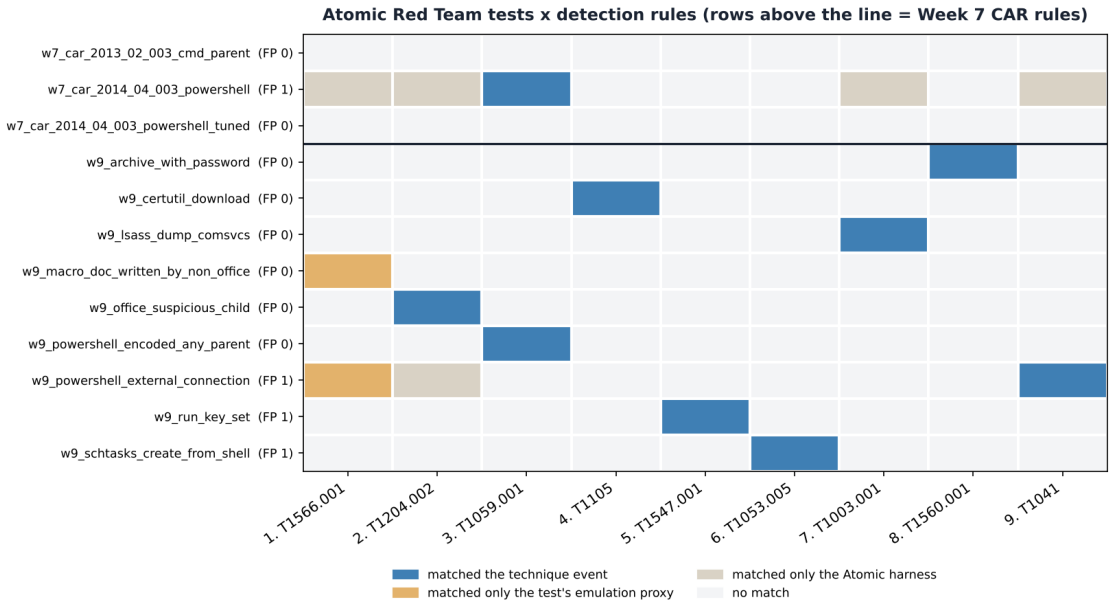
The pipeline is the same as in Week 7: Sigma rule → pySigma → Splunk SPL (`queries/*.spl`) and SQLite (`queries/*.sql`). This week the **Sysmon pipeline is applied to both backends**, so each query carries its EventID (1 process, 3 network, 11 file, 13 registry) and all event types fit in one table. `scripts/run_siem.py` loads the 42 events into SQLite and runs all 12 queries. Each match is attributed to the Atomic step whose UTC window from the run log contains it, which is how a real purple-team exercise scores results. Full log: `docs/execution_output.txt`.

Rule set (`rules/`):

- **Week 7, unchanged:** CAR-2014-04-003 raw, CAR-2014-04-003 tuned, CAR-2013-02-003.
- **Week 9, new:**
  - `w9_office_suspicious_child`
  - `w9_powershell_encoded_any_parent`
  - `w9_certutil_download`
  - `w9_run_key_set` (Sysmon 13)
  - `w9_schtasks_create_from_shell`
  - `w9_lsass_dump_comsvcs`
  - `w9_archive_with_password`
  - `w9_macro_doc_written_by_non_office` (Sysmon 11)

- `w9_powershell_external_connection` (Sysmon 3)

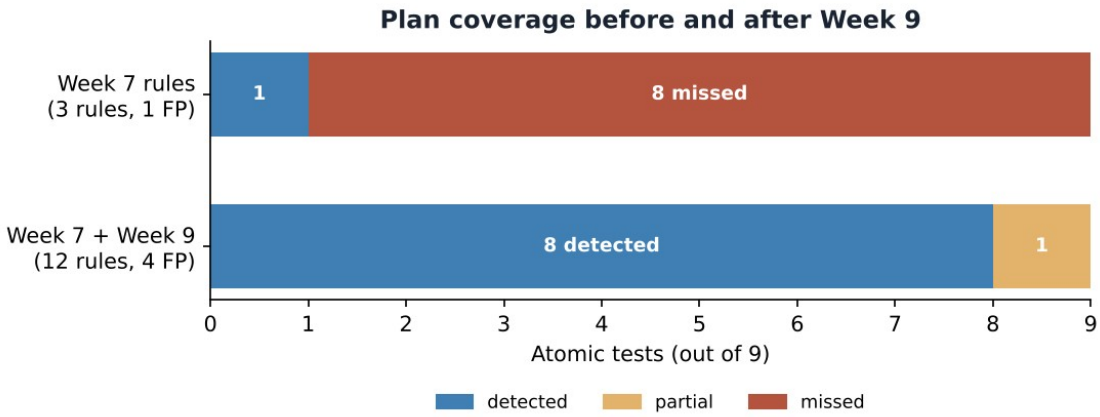
Results



Detection matrix

Step	Technique	Atomic test	Week 7 rules	Week 7 + Week 9 rules	Detected by
1	T1566.001	T1566.001 #1	MISSED (harness only)	PARTIAL	`w9_macro_doc_written_by_non_office`, `w9_powershell_external_connection`
2	T1204.002	T1566.001 #2	MISSED (harness only)	DETECTED	`w9_office_suspicious_child`
3	T1059.001	T1059.001 #17	DETECTED	DETECTED	`w7_car_2014_04_003_powershell`, `w9_powershell_encoded_any_parent`
4	T1105	T1105 #7	MISSED	DETECTED	`w9_certutil_download`
5	T1547.001	T1547.001 #1	MISSED	DETECTED	`w9_run_key_set`

Step	Technique	Atomic test	Week 7 rules	Week 7 + Week 9 rules	Detected by
6	T1053.005	T1053.005 #2	MISSED	DETECTED	`w9_schtasks_create_from_shell`
7	T1003.001	T1003.001 #2	MISSED (harness only)	DETECTED	`w9_lsass_dump_comsvcs`
8	T1560.001	T1560.001 #4	MISSED	DETECTED	`w9_archive_with_password`
9	T1041	T1041 #1	MISSED (harness only)	DETECTED	`w9_powershell_external_connection`



Before and after

- **Week 7 rules only:** 1 of 9 tests detected, with 1 false positive (the approved FIN-WS03 automation).
- **Week 7 + Week 9 rules:** 8 detected, 1 partial and 0 missed, with 4 false positives on the baseline.

Analysis: what the Atomic tests taught us

1. **The Week 7 tuned rule failed both of the predictions it was written for.** The plan expected CAR-2014-04-003 *tuned* to catch step 3, but it matched nothing. There were two reasons. First, the parent of the test's PowerShell is `cmd.exe`, not Office. Second, the test passes `-e`, while the Week 7 rule looks for `-enc`, and PowerShell accepts *any* unambiguous prefix of `-EncodedCommand`. Tuning for precision on four synthetic records had made the rule brittle. `w9_powershell_encoded_any_parent` covers all the short forms and any parent.
2. **"Office spawns a shell" is too narrow.** The plan expected CAR-2013-02-003 to catch step 2. In the real Atomic test the macro runs `ping.exe` **directly from WINWORD.EXE**, with no `cmd.exe` in between, so the rule saw nothing.

`w9_office_suspicious_child` widens the child list to script hosts and LOLBins. It also filters the FIN-WS03 automation by its command line, which is the false positive found in Week 7.

3. **A rule can fire on the test harness and still miss the technique.** Raw CAR-2014-04-003 matched in 5 of the 9 windows. In 4 of them it only matched the `powershell.exe & {…}` wrapper that Invoke-AtomicRedTeam spawns. A naive scoring of "anything fired in the window" would have reported 5/9 instead of 1/9. Labelling harness events separately is what keeps the score honest.
4. **Step 1 is only partial.** Both rules that fired matched how the Atomic test *emulates* delivery, a PowerShell download of an `.xlsm` file, not how a phishing email really lands through Outlook. A real test of T1566.001 needs mail-gateway logs and an Outlook-written attachment. This is recorded as a gap and not counted as a detection.
5. **Coverage costs false positives.** The 9 new rules brought 3 new benign matches: the Teams updater Run key, an admin's backup task, and Update-Help reaching Microsoft. Each one needs an allowlist or a baseline per host, and that is the next tuning step. The persistence and network rules are deliberately `medium` or `low` severity: they are hunting leads, not alerts.

Gaps kept open

- **Sysmon 10 (process access to lsass.exe)** is generated but no rule uses it. Our LSASS rule depends on the comsvcs command line, so NanoDump-style tools (Atomic T1003.001 #4) would evade it.
- **Security 4698 and PowerShell 4104** are not used by any rule yet.
- The T1041 rule only checks "PowerShell talks to a non-RFC1918 address". It does not see process-less exfiltration (browser, BITS) or an internal staging host.

Reproduce

```
cd week9
python3 -m pip install pyyaml matplotlib pysigma pysigma-backend-splunk pysigma-backend-sqlite pysigma-pipeline-sysmon
python3 scripts/fetch_atomics.py        # pinned Atomic YAML -> atomics/selected_tests.json (needs network)
python3 scripts/generate_telemetry.py   # -> data/atomic_run_telemetry.ndjson, data/run_log.csv
python3 scripts/convert_rules.py        # Sigma -> queries/*.spl + *.sql
python3 scripts/run_siem.py             # execute + score (stdlib only)
python3 scripts/make_figures.py
```

In the Splunk lab, ingest the NDJSON (or the real export) into a Sysmon index and paste `queries/*.spl` into Search & Reporting.

References

- [R1] Red Canary: Atomic Red Team, commit a0e3f9bc69. https://github.com/redcanaryco/atomic-red-team

- [R2] Invoke-AtomicRedTeam wiki. https://github.com/redcanaryco/invoke-atomicredteam/wiki
- [R3] MITRE CAR: CAR-2014-04-003, CAR-2013-02-003. https://car.mitre.org/
- [R4] SigmaHQ / pySigma. https://github.com/SigmaHQ/pySigma
- [R5] LOLBAS: Certutil, comsvcs. https://lolbas-project.github.io/
- [R6] Microsoft: about_PowerShell_exe (`-EncodedCommand` abbreviations). https://learn.microsoft.com/powershell/module/microsoft.powershell.core/about/about_powershell_exe

Week 10 — Learning APT Techniques: APT29 TTPs Mapped to ATT&CK

Project and weekly task

Project topic: Detecting Spearphishing Attacks in Corporate Networks. Student: Danial Rahman. Group: CS-2421. Course: Introduction to Threat Hunting (ITH). Assignment 6, part 2. Date: 11 November 2026.

Section 3.3 of the 2026–2027 syllabus sets the Week 10 practice task as: *analyze the TTPs of APT29 or APT41; map the observed techniques to the MITRE ATT&CK framework,* with the Mandiant APT1 report and the CrowdStrike Global Threat Report as recommended reading. We chose **APT29**, because spearphishing is its signature initial-access method and that is our project topic. We compare it briefly with APT41. The increment closes the loop on Weeks 8–9: how much of a *real* adversary does our emulation plan exercise, and how much do our detections see?

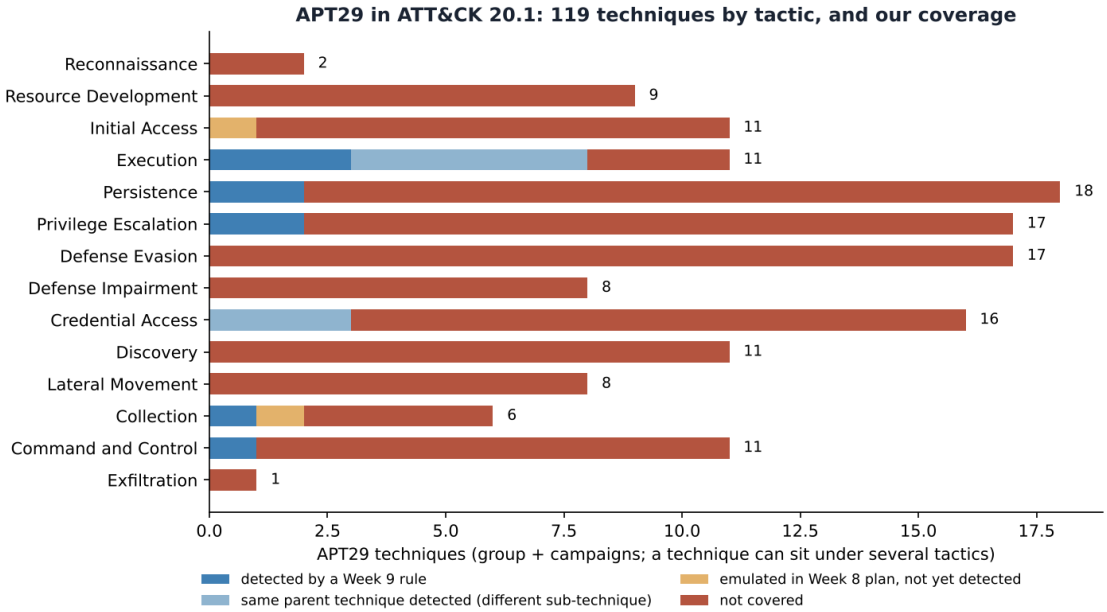
Method and data

All technique data comes from MITRE's official **ATT&CK Enterprise 20.1 STIX bundle**. `scripts/build_apt_profile.py` extracts APT29 (G0016) into `data/apt29_profile.json`: techniques, procedure examples with their source citations, software, and attributed campaigns. It does the same for APT41 (G0096). ATT&CK records technique use at **group level** and at **campaign level** separately, so we keep the two apart. `scripts/analyze_apt29.py` then joins the profile with the Week 8 plan and the Week 9 detection results. Run log: `docs/execution_output.txt`. Full mapping of every technique: `docs/apt29_ttp_table.md`.

APT29 at a glance

- **Attribution (ATT&CK):** Russia's Foreign Intelligence Service (SVR); active since at least 2008. Targets government networks in Europe and NATO countries, research institutes and think tanks.
- **Aliases:** IRON RITUAL, IRON HEMLOCK, NobleBaron, Dark Halo, NOBELIUM, UNC2452, YTTRIUM, The Dukes, Cozy Bear, CozyDuke, SolarStorm, Blue Kitsune, UNC3524, Midnight Blizzard.
- **Size of the profile in ATT&CK 20.1:**
  - 66 techniques at group level

  - 75 techniques in two campaigns: **C0023 Operation Ghost** (2013–2019) and **C0024 SolarWinds Compromise** (2019–2021)
  - **119 distinct techniques** in total
  - 49 software entries, including the Duke families, SUNBURST, TEARDROP, EnvyScout, Cobalt Strike and Mimikatz
- **Initial access (11 techniques):** spearphishing attachment, link and via service (T1566.001/.002/.003); valid accounts (T1078 and three sub-techniques); external remote services (T1133); exploitation of public-facing applications (T1190); supply-chain compromise (T1195.002); trusted relationships (T1199).



APT29 by tactic

APT29 uses 14 of the 15 enterprise tactics in ATT&CK v20, every one except Impact. The heaviest are **Persistence (18), Privilege Escalation and Defense Evasion (17 each) and Credential Access (16)**. This is the profile of an espionage actor that values long, quiet access over fast impact: there are no Impact techniques at all.

Case studies: how APT29 operates

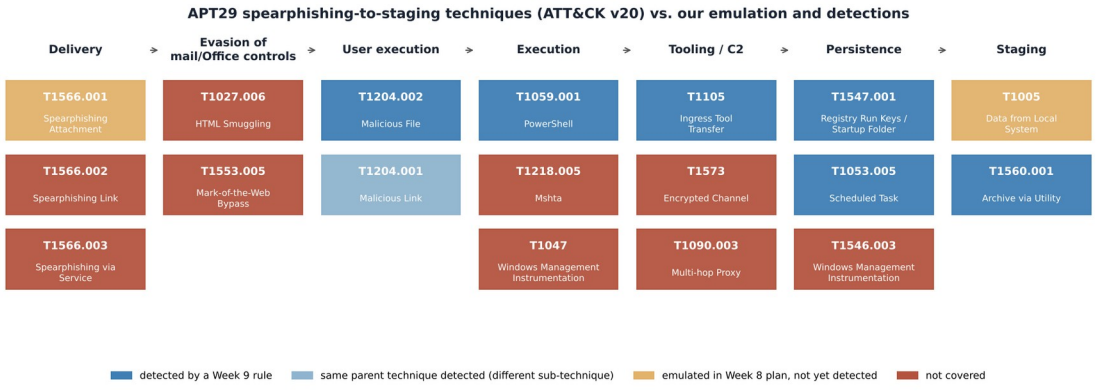
The first four cases use procedure text that ATT&CK cites to vendor reporting. The fifth uses public reporting newer than the ATT&CK campaign data.

1. **The Dukes era (2008–2015): attachments and encoded PowerShell.**
   - APT29 used spearphishing emails with attachments to deliver exploits (T1566.001) and lured users into opening Word documents, PDFs and LNK files (T1204.002) (F-Secure, *The Dukes*; ESET).
   - It *"used encoded PowerShell scripts uploaded to CozyCar installations to download and install SeaDuke"* (T1059.001 + T1105; Symantec, Mandiant).
   - It persisted with **Registry Run keys** (T1547.001) and **named or hijacked scheduled tasks** (T1053.005) (Mandiant, *No Easy Breach*).

- This is almost exactly the chain in our Week 8 plan, steps 1–6.

2. **Operation Ghost (C0023, 2013–2019).** This campaign targeted ministries of foreign affairs in Europe. It used new Duke families (PolyglotDuke, RegDuke, FatDuke), Twitter accounts and steganography for C2 (T1585.001, T1001.002), and WMI event subscriptions for persistence (T1546.003). None of these are covered by our rules.
3. **SolarWinds Compromise (C0024, 2019–2021).**
   - Initial access came through the software supply chain (T1195.002, SUNBURST), not phishing. It was followed by TEARDROP and Cobalt Strike (T1105), DCSync (T1003.006) and forged SAML tokens (T1606.002).
   - For our project the most relevant procedure is: *"APT29 used 7-Zip to compress stolen emails into password-protected archives prior to exfiltration"* (T1560.001). This is exactly Week 8 step 8, and our `w9_archive_with_password` rule detects it.
4. **NOBELIUM email campaign (May 2021).**
   - APT29 sent phishing mail through the legitimate **Constant Contact** service (T1566.003), impersonating USAID (Microsoft MSTIC; Secureworks).
   - The payload was delivered by **HTML smuggling**: an ISO embedded in an HTML attachment (T1027.006). Because the ISO and VHDX containers strip Mark-of-the-Web (T1553.005), Office macro blocking never applies.
5. **Recent tradecraft (public reporting, not yet in ATT&CK campaign data).**
   - In January 2024 Microsoft disclosed that Midnight Blizzard had accessed corporate mailboxes after a **password spray** against a legacy test tenant (T1110.003, T1078.004).
   - In October 2024 Microsoft reported a large spearphishing campaign that used **signed .rdp attachments** (T1566.001) to connect victims to attacker-controlled RDP servers.
   - Both bypass a macro-centred detection strategy completely.

Mapping our project onto APT29



APT29 phishing-to-staging chain vs our coverage

Emulation plan (Week 8). 8 of our 11 plan techniques are used by APT29: T1005, T1053.005, T1059.001, T1105, T1204.002, T1547.001, T1560.001 and T1566.001. The other three are not attributed to APT29 in ATT&CK:

- **T1003.001 LSASS Memory.** APT29 dumps credentials differently: `reg save` of the SAM and LSA secrets (T1003.002/.004) and DCSync (T1003.006).
- **T1041 Exfiltration Over C2 Channel.** APT29 used HTTPS to an archive staged on OWA (T1048.002).
- **T1027.010 Command Obfuscation.**

These are useful corrections for a second version of the plan that is closer to APT29.

Detection coverage (Week 9) of the 119 APT29 techniques:

Coverage	Techniques
Detected by a Week 9 rule	6 (T1059.001, T1053.005, T1547.001, T1105, T1204.002, T1560.001)
Same parent technique detected, different sub-technique (e.g. T1003.002, T1059.003, T1204.001)	8
Emulated but not yet detected (T1566.001 delivery, T1005)	2
Not covered	103

Only **about 12% of APT29** is detected or adjacent to a detection. That is the honest result of a project that focused on one intrusion path. The covered part is APT29's *older, endpoint-centred* phishing chain. Its *modern* tradecraft is almost entirely uncovered: cloud and identity techniques such as T1078.004, T1098., *T1528, T1606.* and T1621, supply chain (T1195.002), and container-based delivery (T1027.006, T1553.005).

`attack/apt29_coverage_layer.json` is an ATT&CK Navigator layer of all 119 techniques, coloured by this coverage. It can be loaded next to the Week 8 and Week 9 layers.

APT29 vs APT41 (comparison)

APT41 (G0096; Wicked Panda, Brass Typhoon, BARIUM) has 82 techniques in ATT&CK 20.1. It shares **19 techniques** with APT29 at group level (Jaccard similarity 0.15), including:

- T1566.001 spearphishing attachment
- T1059.001 PowerShell
- T1053.005 scheduled task
- T1547.001 Run keys
- T1105 ingress tool transfer
- T1078 valid accounts
- T1190 exploitation of public-facing applications
- T1047 WMI

The overlap is mostly the **commodity layer** of Windows intrusion. APT41's dual espionage and financial mission shows up as Impact and many more Discovery techniques, while APT29 leans towards identity and cloud. For a defender this is good news: **5 of our 6 detected techniques**

are also APT41 techniques (all except T1204.002 Malicious File), so the Week 9 rules transfer across both groups.

Recommended next hunts

These are uncovered APT29 techniques with the highest value for a spearphishing-focused hunt. This prioritisation is analyst judgement; the techniques themselves come from ATT&CK.

#	Technique	Data source needed	Why
1	T1566.002 Spearphishing Link	proxy/DNS + Sysmon 11 (zip/iso in Downloads)	APT29's most-cited delivery method; we only emulate attachments
2	T1027.006 HTML Smuggling	Sysmon 11: .iso/.img/.vhdx written by a browser right after an .html opens	NOBELIUM 2021 (EnvyScout)
3	T1553.005 Mark-of-the-Web Bypass	Sysmon 1/11: execution from a mounted ISO/VHDX volume	defeats Office macro blocking
4	T1218.005 Mshta	Sysmon 1: mshta.exe with http/javascript arguments	in our Office-child list, but needs a standalone rule
5	T1546.003 WMI Event Subscription	Sysmon 19/20/21	used in Operation Ghost and SolarWinds
6	T1078 Valid Accounts	4624/4625, VPN and Entra ID sign-in logs	APT29 often skips phishing with password spray + valid accounts

Conclusions across Weeks 8–10

1. **A written plan is a set of predictions, and the Atomic run disproved two of them** (Week 7 tuned PowerShell rule and CAR-2013-02-003). Without emulation those rules would still be considered "coverage".
2. **ATT&CK makes the gap measurable.** Our detections are good for the classic Dukes-era phishing chain, but that chain is only about 12% of what APT29 does today.
3. **The next increment should move left and sideways:** cover the delivery containers (HTML smuggling, ISO, RDP files) and the identity plane (password spray, token theft), where APT29 has moved.

Limitations

- ATT&CK records only *publicly reported* procedures, so the absence of a technique does not mean APT29 never uses it. For example, ATT&CK does not attribute T1041 to APT29, but reporting may exist that ATT&CK has not added yet.
- Campaign-level data exists only for C0023 and C0024. The 2023–2024 activity is described from Microsoft reporting, not from ATT&CK.
- Coverage is measured against our synthetic Week 9 run. A real lab run could move individual techniques between categories.

Reproduce

```
cd week10
python3 -m pip install pyyaml matplotlib
# optional, refreshes data/*.json from MITRE's STIX bundle:
python3 scripts/build_apt_profile.py /path/to/enterprise-attack.json
python3 scripts/analyze_apt29.py      # reads ../week8 plan and
../week9 results
```

References

- [R1] MITRE ATT&CK: APT29 (G0016). https://attack.mitre.org/groups/G0016/ ; Operation Ghost (C0023), SolarWinds Compromise (C0024). STIX data: https://github.com/mitre-attack/attack-stix-data
- [R2] MITRE ATT&CK: APT41 (G0096). https://attack.mitre.org/groups/G0096/
- [R3] F-Secure, *The Dukes: 7 years of Russian cyberespionage*. https://www.f-secure.com/documents/996508/1030745/dukes_whitepaper.pdf
- [R4] Mandiant, *No Easy Breach* (DerbyCon 2016). https://www.slideshare.net/slideshow/no-easy-breach-derby-con-2016/66447908
- [R5] Microsoft MSTIC, *New sophisticated email-based attack from NOBELIUM* (27 May 2021). https://www.microsoft.com/security/blog/2021/05/27/new-sophisticated-email-based-attack-from-nobelium/
- [R6] ESET Threat Report T3 2021. https://www.welivesecurity.com/wp-content/uploads/2022/02/eset_threat_report_t32021.pdf
- [R7] Microsoft MSRC, *Microsoft actions following attack by nation state actor Midnight Blizzard* (19 Jan 2024). https://msrc.microsoft.com/blog/2024/01/microsoft-actions-following-attack-by-nation-state-actor-midnight-blizzard/
- [R8] Microsoft Threat Intelligence, *Midnight Blizzard conducts large-scale spear-phishing campaign using RDP files* (29 Oct 2024). https://www.microsoft.com/en-us/security/blog/2024/10/29/midnight-blizzard-conducts-large-scale-spear-phishing-campaign-using-rdp-files/
- [R9] Mandiant, *APT1: Exposing One of China's Cyber Espionage Units* (2013), syllabus reading, used for the report structure. CrowdStrike Global Threat Report (syllabus reading).